Information Security Policy

Company: RS Solutions Inc. (operating Bargain Bay and RS Solutions)

Address: 1135 Squires Beach Rd, Pickering, ON L1W 3T9, Canada

Policy owner: Owner / Director (Service@rssolutions.ca)

Version: 1.0

Effective date: November 2, 2026

Review cycle: at least once every 12 months, and after any security incident or major system change

1. Purpose and scope

This policy sets out how RS Solutions protects the information it holds, in particular customer personal information and financial data, including bank transaction data obtained through Plaid.

It applies to every person with access to our systems (owner, employees, contractors, drivers, sales staff, accountants) and to all systems that store or process company data: the Bargain Bay and RS Solutions web applications, the production database, the master inventory tracker (Google Sheets), email, and the third-party services listed in section 9.

2. Roles and responsibility

- The **owner** is accountable for information security, approves this policy, grants and revokes administrator access, and decides on incident response.
- **All personnel** must follow this policy and report suspected incidents immediately to the owner.
- Access to company data is granted only to people whose job needs it (section 4).

3. Data we handle and how it is classified

Class	Examples	Handling
Restricted	Bank credentials-derived tokens (Plaid access tokens), API secrets, bank account details, authentication secrets	Never in source code, email or chat. Stored only as protected environment variables or in the production database. Admin-only.
Confidential	Customer names, addresses, phone numbers, emails, orders, invoices, financial records, cost and profit data	Accessible only to authorised staff through authenticated systems.
Internal	Operating procedures, inventory, internal reports	Staff only.
Public	Product listings, published policies	No restriction.

We never see or store a customer's or the company's online banking username or password. Bank connections are made inside Plaid Link; we receive only an access token and transaction data.

4. Access control

- **Authentication.** Every person has an individual account. Passwords are stored only as salted bcrypt hashes. Sessions use signed tokens in `httpOnly` cookies. Where a sign-in provider is used (Google, Microsoft), we accept only verified email addresses.
- **Least privilege.** Roles are separated: administrator, sales/staff, dispatch coordinator, accountant, driver, and marketplace vendor roles. Each role can reach only the screens and data its job requires. Cost, profit, payroll, banking and financial reports are administrator-only (accountants have read access to the financial records pack). This separation is enforced on the server, not only hidden in the interface, and is covered by an automated test that calls every administrative endpoint as an unauthorised user.
- **Provisioning and removal.** Access is granted by the owner and recorded. Access for staff, accountants and dispatch coordinators is held in the database so it can be revoked immediately; revoked grants are kept as history. Access is removed on the day a person leaves or changes role.
- **Multi-factor authentication.** Marketplace vendor owner accounts use time-based one-time-password (TOTP) two-factor sign-in with recovery codes. The owner must use multi-factor authentication on all third-party administrator accounts that offer it (hosting, database, Google, Plaid, domain registrar, email).
- **Administrator actions are logged.** Money-moving and configuration changes (invoices, refunds, orders, clearance pricing, coupons) are written to an append-only audit log recording who, what and when.

5. Protection of data

- **In transit.** All traffic to our applications and to every third-party API uses HTTPS/TLS.
- **At rest.** The production database is a managed PostgreSQL service whose storage is encrypted at rest by the provider. Highly sensitive vendor bank account numbers are additionally encrypted in the application with AES-256-GCM.
- **Plaid tokens.** Plaid access tokens are held server-side only, are never sent to a browser, and are used only to retrieve transactions for the company's own accounts. *Planned improvement: encrypt the stored Plaid access tokens at the application level, as is already done for vendor bank details..* A bank connection can be removed at any time by an administrator, which also revokes the token at Plaid.
- **Secrets.** API keys and secrets are kept in the hosting provider's protected environment variables, not in source code or documents. Secrets are rotated when a person with access leaves or if exposure is suspected.
- **Data minimisation.** We request only the Plaid Transactions product, and only for the company's own business accounts. Imported bank lines are used for bookkeeping and tax review. Transfers between the company's own accounts are not imported.
- **Test and staging.** Non-production deployments are prevented from emailing or texting real people, from writing to the master inventory tracker, and from placing calls.

6. Secure development and change management

- All source code is in a private version-controlled repository; changes are made on branches and deployed through the hosting provider's build pipeline.
- Database changes are made through numbered, checksummed migrations; an applied migration cannot be silently altered.
- An automated test suite runs before changes are merged, including tests for access control, financial calculations and data integrity.

- Third-party dependencies are kept to a minimum and updated when security fixes are published.
- Production error monitoring is in place so failures are visible rather than silent.

7. Availability, backup and recovery

- The production database has provider point-in-time recovery, plus scheduled exports to a separate store. A restore procedure is documented and tested.
- Uploaded files (proof-of-delivery signatures, photos) and the master inventory tracker are copied off-site on a schedule.
- A daily health report is emailed to the owner confirming scheduled jobs ran and flagging missing configuration.

8. Incident response

1. **Report.** Anyone who suspects a breach, lost device, leaked key or misuse of access must tell the owner immediately.
2. **Contain.** The owner revokes the affected access, rotates affected secrets, and, for a Plaid-related incident, removes the bank connection and rotates the Plaid secret.
3. **Assess.** Determine what data was affected, for whom, and for how long, using the audit log and hosting logs.
4. **Notify.** Where personal information is involved and there is a real risk of significant harm, notify affected individuals and the Office of the Privacy Commissioner of Canada as required by PIPEDA, and notify Plaid and any other affected provider without undue delay.
5. **Record and learn.** Every incident is recorded with its cause and the corrective action, and this policy is updated if needed.

9. Third-party providers

We use reputable providers and review them when we adopt them and at least annually: Plaid (bank data), Vercel (hosting), Neon (database), Google (workspace, tracker), Stripe (card payments, currently disabled), Resend (email), Twilio (SMS and voice), Sentry-compatible error monitoring, and Meta and Google advertising platforms (spend reporting only). We share with each provider only the data it needs to perform its service. Providers are expected to maintain their own security programs and certifications.

10. Privacy, retention and disposal

- Personal information is collected only for stated business purposes and handled under our published privacy policy and Canadian privacy law (PIPEDA).
- Marketing messages are sent only with consent or where the law permits, with a working unsubscribe, and opt-outs are recorded and honoured.
- Financial records are retained as required for tax purposes (generally six years). Data no longer needed is deleted or anonymised. Disconnected bank connections stop receiving new data immediately.
- Backups and database exports contain customer data and are stored only in access-controlled locations; they are excluded from source control.

11. Devices and physical security

- Company devices used for administration must have a screen lock, disk encryption, and current operating system updates. Lost or stolen devices are reported at once and the person's sessions and access are revoked.
- The warehouse and office at 1135 Squires Beach Rd are locked outside business hours. Paper records containing personal information are kept secured and shredded when no longer needed.
- Shared warehouse computers must be signed out after use.

12. Training and enforcement

New staff are told about this policy when access is granted and are reminded of it at least annually. Breaching this policy may result in loss of access and other disciplinary action.